



File No: EXP202304633

RESOLUTION OF TERMINATION OF THE PROCEDURE BY VOLUNTARY PAYMENT

From the procedure initiated by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 8, 2024, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U. (hereinafter, the respondent), through the Agreement that is transcribed:

<<

File No: EXP202304633

AGREEMENT TO INITIATE SANCTIONING PROCEDURE

From the actions carried out by the Spanish Agency for Data Protection and based on the following

FACTS

FIRST: On February 17, 2023, the Division of Technological Innovation of this Agency was notified of a personal data breach reported by 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U. with NIF A86521309 (hereinafter, VIVUS) as the data controller. As a consequence of the known facts, on April 11, 2023, the Director of the Spanish Agency for Data Protection ordered the General Subdirectorate of Data Inspection (SGID) to carry out the appropriate preliminary investigations in order to determine a possible violation of data protection regulations.

SECOND: The General Subdirectorate of Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the supervisory authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

On February 17, 2023, the controller 4FINANCE SPAIN FINANCIAL SERVICES (hereinafter VIVUS) made an initial notification of the personal data breach with entry record REGAGE23e00010208403, in which it stated that it had suffered a breach of confidentiality due to unauthorized access to customer data, including basic, identifying, and contact information of a total of 427 employees. The controller indicated that they were still investigating the incident.

On March 31, 2023, an additional notification of the personal data breach was received with entry record REGAGE23e00021779018, in which it was stated:

- Description of the incident: consisting of unauthorized access to customer profiles in VIVUS's database. The incident was investigated internally.
- Regarding the start date, they claim it is unknown, while the detection date is determined to be February 14, 2023.
- They indicate that the affected data was not encrypted.
- Regarding the consequences for the affected individuals, they state that they are not adversely affected, except for some very limited inconveniences, but in any case reversible.
- As for the categories of affected data, they include: basic data (e.g., name, surname, date of birth), ID number, NIE, passport and/or any other identifying document, payment method data (bank card, etc.), and contact data.
- Number of affected individuals: 9636 (There are no minors), they state that they will not be communicated.
- They state that they have informed law enforcement authorities.
- Detection method: Communication from an affected individual.
- A summary is included stating that through a brute force attack testing combinations of ID/password and Email/password, cybercriminals gained access to the personal data of 9636 individuals' customer profiles. This data included name and surname, ID/NIE, date of birth, postal address, email, IBAN, mobile phone, and pseudonymized bank card. They state that 139 customers have been victims of fraud as a credit was requested in their name through the application, and once granted, they

contacted the customer via WhatsApp to request immediate repayment to a bank account number of the cybercriminals.

- They state that as a reactive measure they have implemented 2FA.
- The controller states that they will not communicate to the affected individuals as they do not consider it a high risk.

From this authority, the controller was ordered to carry out the communication of the personal data breach to the affected individuals in accordance with Article 34 of the GDPR without undue delay and in order for them to take the measures they deem appropriate to avoid any risks that may affect them. On April 11, 2023, and entry record REGAGE23e00023503645, a document was received from VIVUS confirming the sending of individualized communication to all customers affected by the breach, providing a screenshot of an email where only the sender's address (vivus@sm.vivus.es) is visible (but not the recipient addresses). The body of this email contains information about the incident that occurred, about the data that may have been affected, the measures adopted by the company after the incident, the

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
3/33

recommendations on possible measures to be adopted by the affected client and the possible contact avenues to obtain further information.

Furthermore, regarding the indicated breach, the following complaints have been received by this Agency from affected individuals:

Complaint 1: on February 3, 2023, and entry registration REGAGE23e00007166247, a complaint was received from A.A.A. related to the alleged identity theft as a loan was requested in their name and granted by VIVUS, deposited into a bank account in their ownership. The transfer of this complaint to VIVUS was made on March 16, 2023, and a response was subsequently received on April 13, 2023, with entry registration REGAGE23e00024080156.

Complaint 2: on February 5, 2023, and entry registration REGAGE23e00007349177, a complaint was received from B.B.B. related to the alleged identity theft as a loan was requested in their name and granted by VIVUS, deposited into a bank account in their ownership. The transfer of this complaint was made on March 16, 2023, and a response was received on April 13, 2023, with entry registration REGAGE23e00024080388.

Complaint 3: on February 5, 2023, and entry registration REGAGE23e00007333527, a complaint was received from C.C.C. related to the alleged identity theft as a loan was requested in their name and granted by VIVUS, deposited into a bank account in their ownership. The transfer of this complaint to VIVUS was made on March 16, 2023, and a response was received on April 13, 2023, with entry registration REGAGE23e00024082969.

Complaint 4: on February 6, 2023, and entry registration REGAGE23e00007574937, a complaint was received from D.D.D. related to the alleged identity theft as a loan was requested in their name and granted by VIVUS, deposited into a bank account in their ownership. A copy of the police report and a copy of the ID are provided. The transfer of this complaint to VIVUS was made on March 16, 2023, and a response was received on April 13, 2023, with entry registration REGAGE23e00024084764.

Complaint 5: on February 11, 2023, and entry registration REGAGE23e00008763533, a complaint was received from E.E.E. related to the alleged identity theft as a loan was requested in their name and granted by VIVUS, deposited into a bank account in their ownership, of which this company was aware. A copy of the complaint filed with the National Police is attached. The transfer of this complaint to VIVUS was made on March 16, 2023, and a response was received on April 13, 2023, with entry registration REGAGE23e00024084642.

Complaint 6: on February 23, 2023, and entry registration REGAGE23e00011468445, a complaint was received from F.F.F. related to the

C/ Jorge Juan, 6
www.aepd.es

presumed identity theft in the application for a loan granted by VIVUS and deposited into a bank account held by the individual. The transfer of this complaint to VIVUS was made on March 16, 2023, and a response was received on April 13, 2023, with entry registration REGAGE23e00024084525. On March 16, 2023, the responsible party at VIVUS was informed of the various complaints received, requesting the following information:

- Detailed and chronological description of the facts and specification of the causes of the incident.
- Number of affected individuals, category of the data involved, and possible consequences for the affected parties.
- Actions taken to resolve the incident and measures to prevent it from happening again.
- Risk analysis of the processing, preventive security measures implemented, and impact assessment if applicable.
- Copy of the Record of Processing Activities.
- If the affected individuals have been notified, the channel used, date of communication, and details of the message sent. In case communication was not made, indicate the reasons.

VIVUS responded on April 13, 2023, and individually addressed each of the transfers made by this entity. From the content of the mentioned writings, the following relevant information is extracted:

- For each of the complaints, a detailed analysis of the specific customer's impact scenario is provided, indicating the dates when they became aware of the corresponding incident, as well as the details related to the communications they had with each customer.

- Regarding the causes that triggered the incident, it states:

☐ That on August 10, 2022, they received the first notification from a customer, who reported having received money in their bank account due to a loan that they had not requested.

☐ That the attackers made numerous login attempts using different IP addresses and using the customer's ID or email (as the username) and a password, obtained from external sources unrelated to VIVUS. Once they gained access, they requested loans in the name of the customer, which were accepted and disbursed into the customer's account. Subsequently, the attackers contacted the customer via WhatsApp, requesting the return of the amount to a bank account number controlled by them.

- It claims that there is a total of 9,636 affected individuals and that the type of data affected was that existing in the personal area of the web user. Specifically, it included: Name and Surname, Date of Birth, Postal Address, Email, Mobile Phone, ID/NIE, IBAN, pseudonymized bank card, as well as data on active loans that the user had not yet completed, such as the amount, accrued interest, term, and due date.

- Regarding the possible consequences for the affected individuals, it maintains that the nature of the set of personal data accessed does not...

C/ Jorge Juan, 6

www.aepd.es

provided substantial information about the financial situation and were considered not to pose a high risk to the rights and freedoms of those affected.

-

In relation to the actions taken by the responsible party to resolve the incident, they report the adoption of the following measures:

- ☐ Register the breach in the incident log.
- ☐ Report to the Police.
- ☐ Official communication to various clients and through the website regarding information that the entity does not use WhatsApp.
- ☐ Reset all user passwords as of February 11, 2022.

- ☐ Implementation of a two-factor authentication system implemented on February 21, 2023.
- ☐ Modification of the login password policy, increasing its complexity and requiring all users to change it.
- ☐ Improvement of the SIEM system's operation, reviewing the internal incident response procedure.
- ☐ Inclusion of clients affected by fraud in a specific category to avoid resulting consequences.
- ☐ Sending communication to all affected clients. Their accreditation will be requested in a new requirement.

-

In response to our request for them to provide the risk analysis and the security measures concluded, they state the following: "The processing of client access data to web profiles and the acquisition of online applications does not pose high risks for data protection, therefore a Data Protection Impact Assessment of such processing has not been carried out. However, to ensure technical and organizational measures, the following security measures specifically relevant to the reported security incident were implemented:

- ☐ Security monitoring.
- ☐ Password policy: minimum complexity rules are defined for the passwords used to log in to client profiles.
- ☐ Protection of web applications.
- ☐ Firewalls and intrusion prevention systems. Protection against Malware.
- ☐ Reports, management, and investigation of security incidents: the management of security incidents is well established and meets the expectations of the 4finance Group."

-

They state that, from September to the end of November 2020, the information security department conducted a comprehensive risk assessment of information security with the aim of evaluating and improving security measures in the areas of software, network, and data distribution, people, and processes. As a result, security measures were improved to protect the organization against automated brute force attacks related to password discovery.

-

They indicate that an external penetration test of the application vivus.es was conducted by a professional services firm between February 9 and February 17, 2022.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/33

- They provide the Record of Processing Activities, in English, with the processing activity affected by the breach: "Customer Registration and Contract Signing."
- They indicate that the violation has been communicated to all affected customers on April 11, 2023, and that it was initially reported to the AEPD on February 17, 2023.
- They assert that among the measures adopted to prevent new incidents, the implementation of the two-factor authentication (2FA) system in the web service has been key.

In the context of this investigation, on June 30, 2023, an initial request for information is made to the responsible party VIVUS:

- To provide evidence of the communication of the breach made, as only the text of the communication had been submitted.
- The adoption of existing organizational measures within the organization to manage security incidents affecting personal data (the management of personal data breaches) is requested.
- To provide evidence of the communications maintained by the entity with the first affected customer who contacted the company on August 10, 2022.
- To provide evidence of the risk analyses conducted to ensure both the security of the processing and the rights and freedoms of the affected individuals, as well as, where applicable, the impact assessments.

- To provide evidence of the reactive measures implemented after the security breach, focusing on those measures aimed at stopping brute force attacks and monitoring user traceability.
- To provide evidence of the complaint filed with the security authorities.
- Investigate the details of the existing procedure to identify customers requesting loans through the web area.

On July 19, 2023, and under entry records REGAGE23e00048973515 and REGAGE23e00049304085, a response to the previous request is received, extracting the following relevant information for the investigation:

- They state that the access credentials used were already available to the attackers prior to the breach, possibly from leaks from third parties and external sources, so the present attack does not correspond to a brute force attack but to a "credential stuffing" attack.
- They provide a document with the total volume of failed login attempts broken down by dates. From their analysis, the days between February 4 and February 14, 2023, stand out, with peaks of up to 18 million failed attempts in a single day.
- They indicate that in the moments prior to the breach, VIVUS's systems were protected against a high number of failed connections in the following manner:
 - ☐ Protection against "brute force" attacks was implemented in the web application vivus.es, increasing the authentication wait time after a failed attempt for a specific user.

C/ Jorge Juan, 6
 www.aepd.es
 28001 – Madrid
 sedeagpd.gob.es
 7/33

After the following failed authentication attempts, the wait time was doubled for these users.

- ☐ Protection against a large number of false web requests was implemented in the Imperva WAF software, primarily to prevent denial of service (DoS) attacks. The configuration adjustment consisted of blocking any source that generated more than 450 requests per second.
- ☐ They claim that the security systems for the product vivus.es were prepared to detect and alert about common attack patterns in web applications (SQL Injections, Cross Site Scripting (XSS), File Inclusion Attacks, Directory Traversal Attacks, DoS/DDoS attacks, etc.), but did not detect or alert about a high number of failed connection attempts.

-

A recording of the phone call received from the affected client on August 11, 2022, at 20:46 hours is provided, in which the affected user reports having received money from a loan that they did not request. Subsequently, on August 12, 2022, this client sent via email a copy of the filed complaint, which was responded to by VIVUS on August 17, 2022, informing the client of the following: "our company has proceeded to activate the applicable procedure for these cases, which includes managing the file as a fraud case, meaning that all debt recovery actions will be halted since once the facts have been reported, it will not be claimed by us."

-

From the preliminary report of the INFOSEC director (Security Department of VIVUS) drafted on March 15, 2023, the following statements are extracted:

- ☐ On February 21, 2023, 2FA was implemented, which halted the attack.
- ☐ There were 3,905 successful cases out of 218,401 attempts made using a combination of ID/Password.
- ☐ There were 6,977 successful cases out of 2,728,941 access attempts made by the attackers using combinations of Email/Password.

☐

From the total successful accesses, they claim evidence of access to data from a total of 9,497 VIVUS clients.

-

They provide two penetration tests conducted in February 2022 (on the VIVUS mobile application) and June 2023 (on the web application that provided access to the personal area of clients). From the analysis of these reports, it is concluded that the vulnerabilities detected are not linked to the attack vector of the current security breach.

-

They state that each detected incident was analyzed and managed according to the incident management procedure, and that the risk analysis was updated. The previous incident management procedure is documented.

-

Four documents with different analyses and evaluations of the severity of the incident are provided, conducted at different times (as cases were discovered), using an internal methodology based on ENISA's own methodology. In these analyses, a quantitative value was assigned to the risk level of the incident, evaluating three main parameters:

☐

The context of the breach (with 1 being minimum and 4 being maximum).

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/33

☐ The ease of identification of the affected person (with a value between 0 and 1 at most)

☐ The circumstances in which the breach occurred (with a severity value from 0 to 2 at most).

After the analysis, a final value was assigned to the risk level of the incident, using the following formula: [Incident Severity = (Context * Ease of Identification of the Affected) + Circumstances].

From the analysis of each document provided with the previous evaluations, the following is extracted for this report:

☐ A first document is provided with the initial assessment of the incident when only one affected case was known, which is signed on August 11, 2022, by the DPD of the entity. To quantify the risk, the minimum value was assigned to the context (1), a value of 0.75 to the Ease of Identification (which had the following meaning according to the methodology: "Identification is possible from the violated data, with the need for investigation to discover the identity of the individual"), concluding the evaluation that the incident did NOT have sufficient substance to be communicated to the AEPD. This contrasts with the type of data leaked through the customer web area, as the set of this data allowed for easy identification of the individual without the need for additional special investigation.

☐ A new document is provided with a second assessment of the incident when 11 affected customers were known, signed by the DPD on September 1, 2022, concluding with a LOW risk value, stating that "the severity of the incident is NOT of sufficient substance to warrant notification to the competent authority or to the affected parties." In the risk assessment, a value of 0.75 was also assigned to the ease of identification, with the maximum value of the scale used being 1, meaning "Identification is possible from the leaked data without the need to conduct a special investigation to discover the identity of the individual." The set of data that was being leaked through the customer web area included, among others, Name and Surname, Date of Birth, Postal Address, Email, Mobile Phone, DNI/NIE, which are sufficient to obtain identification of the affected person without the need for special investigation.

☐ A third document is provided with the assessment of the incident when 83 affected customers were known, signed by the DPD on November 14, 2022, resulting in a LOW risk value, stating that "the incident does NOT have sufficient substance to warrant communication of the security breach to the Spanish Agency for Data Protection or to the affected parties, considering that the personal information allegedly compromised was minimal, and taking into account that access has been

completely restricted.” The same value was assigned for Context and Ease of Identification as in previous points.

☐ A document with the assessment of the incident when the following information was available: “fewer than 35,000 successful login attempts, but

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/33

The extent of the access data is unknown; currently, 427 clients have been defrauded (as of February 17, 2022). This document is signed by the DPD on February 17, 2023, and the assessment concludes a MEDIUM risk level, assigning a maximum value of 1 to the Ease of Identification of the affected client (higher than the value of 0.75 given in previous documents). However, the set of personal data leaked was the same as that for the previously affected clients. The result of this analysis led to the following conclusion: “[...] it must be communicated to the Spanish Agency for Data Protection. However, in view of the category of data breached, it is not considered that there are risks to the rights and freedoms of the data subjects, as the personal information breached is minimal, thus concluding that it is not necessary to communicate to the clients.”

☐

Within the four previous documents, there is a section that refers to the assessment of the incident by the security department of VIVUS: “Severity classification determined by the Information Security Unit in accordance with the Information Security Incident Response Procedure: HIGH SEVERITY (Level 1) due to the financial impact.” Despite this statement, it was assessed as unnecessary to notify the incident.

-

In relation to the four previously analyzed documents in which VIVUS concluded a level of risk and severity of the breach, this inspection proceeded to conduct a simulation with the Asesora-Breach tool, using the same data that VIVUS already had in September 2022, resulting in the obligation to notify the breach to this Agency without undue delay. Similarly, the Comunica-Breach tool was used with the information available to the responsible party in September 2022, resulting in “You should communicate the breach to the AEPD.” The input data used in both tools were as follows:

☐

Sector of activity: Financial Entity

☐

The breach is a consequence of a cyber incident with unauthorized access to personal data.

☐

Affected data: basic, ID number, postal address, phone, email, financial data without payment means.

☐

Affected persons: 56 (information that was already available to the responsible party as of September 27, 2022, the date on which VIVUS filed a complaint providing the list of known affected individuals at that time).

☐

For the possible consequences, the simulation considered the least possible damage (despite the fact that the actual and known consequences at this date were possibly of greater severity), assigning the value: “people may encounter some very limited and reversible inconveniences that they will overcome without problem.”

-

Taking into consideration the severity assessment procedure of ENISA, Recommendations for a methodology of the assessment of severity of personal data breaches, which VIVUS has established as a reference:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

- ☐ The Context (DPC) was valued at 1; however, a higher value should have been assigned, as according to this methodology (the present inspector provides the unofficial translation into Spanish):
 - ☐ Simple data, Preliminary basic score = 1. The DPC score could be increased by 1, for example, when the volume of "simple data" or the characteristics of the data controller are such that profiling of the individual can be enabled or assumptions can be made about the individual's social/financial situation, resulting in DPC = 2, or:
 - ☐ Financial data, Preliminary basic score = 3. The DPC score could be reduced by 1, for example, when the specific dataset includes certain financial information but does not yet provide any significant insight into the individual's financial situation (for example, simple bank account numbers without further details), resulting in DPC = 2, or:
 - ☐ Financial data, Preliminary basic score = 3. The DPC score could be increased by 1, for example, when, due to the nature or volume of the specific dataset, complete financial information is disclosed (for example, credit card) that could enable fraud or create a detailed social/financial profile. DPC = 4.
- ☐ The Ease of Identification of the affected individual should be valued as EI = 1, and not a lower value (VIVUS assigns a value EI = 0.75), as analyzed in the previous point.

It is concluded that the value assigned by VIVUS to the different variables of the severity calculation formula was lower than what should have been assigned, given the scenario that was being understood regarding the security incident, resulting in a final severity outcome that could be between MEDIUM and VERY HIGH. This outcome would have led VIVUS to report the incident to the AEPD and to the affected individuals from the first occurrence.

- Regarding the complaint filed by the data controller, the response to the request states: "the affected cases were collected manually, and given the difficulty in identifying them through the partial information available, up to 4 extensions of the initial complaint were necessary," providing the following documentation in the response.

- ☐ Copy of the initial complaint filed on August 12, 2022, with information about the affected client on August 11, 2022.
- ☐ Copy of the extension to the previous complaint filed on September 28, 2022, in which they state that new clients have been affected in the following days, with fraudulent loan requests totaling 42,610 euros and having been defrauded of 19,830 euros. In this extension, they provide a list with the data of the affected clients to whom VIVUS made the deposit of the amount of the loan requested fraudulently, with approximately 56 different bank account numbers of distinct clients found in this list. The analysis of this list by the present inspector highlights that the same IP used in the loan request...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

of August 10, 2022 (of which notice was received on August 11, 2022, after receiving communication from the affected client), was subsequently used to successfully request two new fraudulent loans on a later date, on October 8, 2022, at 10:53 and at 11:11.

☐

In the substantiated complaints, VIVUS states that the attackers had entered the personal area of each of these clients and had requested a new loan in the remote contracting modality in the name of the affected client.

- They provide a copy of a document with the general conditions of the loan that are accepted (by checking a checkbox) at the time of the online loan application.
- In response to our request to detail the existing procedures for identifying a client when a loan was requested through the web portal, they state that there are two possible identification pathways:

☐

To request a FIRST LOAN, the so-called "onboarding procedure" is used. They claim that this procedure was not used by the attackers, as all affected clients had previously requested a first loan.

This initial identification procedure consists of:

☐

On the first screen, contact details are requested, and consent for privacy policy and commercial communications is obtained.

☐

On the second screen, a DNI number and a password are required to create the account or profile.

☐

On the third screen, name, surname, and date of birth are requested.

☐

On the fourth screen, an address in Spain is requested.

☐

On the fifth screen, a phone number is requested and subsequently verified by sending an SMS with a unique one-time code that the user must enter.

☐

On the sixth and final screen, different options for identity verification are offered, either by providing Online Banking credentials (through the TINK service) or by providing supporting documentation through a form and waiting for a phone call to verify the data.

☐

To request SECOND AND SUBSEQUENT loans (the only pathway affected by the security incident), only identification in the client's personal web area is required, using user credentials (DNI or EMAIL + Password). Once logged into the web area, it was sufficient to select the amount of money to be requested, the desired repayment term, and accept the contracting conditions by activating a verification checkbox.

- Regarding this identification process, they claim to have adopted and implemented the following reactive measures after the security breach:

☐

The resetting of all customer passwords so that when customers access their personal area, they are required to establish a new password.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/33

☐

Implementation of a second factor of authentication (2FA), generating a 4-digit verification code that is sent via SMS to the customer's registered phone number. This two-factor authentication system (2FA) was subsequently reinforced in April 2023 by the addition of two new rules (a 5-minute lockout after 3 failed attempts, requiring a new verification code, and the need for a new code if the customer logs in and out of their profile).

-

They provide an updated document of the internal protocol for incident management, which was updated on April 29, 2023. The modifications introduced in it have consisted of:

☐

Adjusting the timelines for the phases of response to internal incidents, in case of delays in detection, to comply with the GDPR notification deadline.

☐

Including the possibility of involving external legal experts in the response to personal data breaches.

☐

Reviewing the risk assessment template for personal data breaches, including a new enhanced severity calculator.

-

They provide the following reactive technical measures implemented to improve the detection of security incidents:

□

When failed authentication attempts from a single source IP address exceed the defined daily thresholds, the Splunk SIEM system generates a real-time alert that is sent to an alert email for the security department and to a Slack channel.

□

When successful authentication events originate from a single source IP address and access more than 4 distinct customer accounts in a single day, a real-time alert is generated by the Splunk SIEM system and sent to an email for the security department.

□

When attackers use static IP addresses for an extended period, these are added to a special blacklist, and in the event of a subsequent authentication attempt, a real-time alert is generated by the Splunk SIEM system and sent to the alert email for the security department.

-

In response to our request for risk analyses for the processing activities affected by the breach, they make the following statement: "In May 2022, based on the planning of a new onboarding process (completed in October 2022), the corresponding Risk Analysis regarding Data Protection related to the processing activity called CUSTOMER REGISTRATION AND CONTRACT SIGNING was carried out." A document is provided certifying this risk analysis for the rights and freedoms of the natural persons affected by the processing of the mentioned activity. From their analysis, the following is extracted:

□

It was created on May 6, 2022.

□

Threats and risk factors for the rights and freedoms of the data subjects are identified, differentiating between inherent risk and residual risk, referencing whether the risk has been fully mitigated.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/33

or partially. However, the security measures concluded as a result of this analysis to mitigate the risks are not listed.

□

A section of conclusions is included where it is stated that the level of inherent risk is HIGH and residual MEDIUM, and the following assertion is also made: "the analyzed activity involves, among others, the creation of profiles on which decisions are made that may produce legal effects for individuals. The above, based on the document entitled LISTS OF TYPES OF DATA PROCESSING THAT REQUIRE IMPACT ASSESSMENT RELATIVE TO DATA PROTECTION from the Spanish Agency for Data Protection, implies an obligation for 4FINANCE as the data controller to carry out a mandatory DPIA of the analyzed processing."

-

A document is accredited for the data processing activity "Customer Registration And Contract Signing," dated May 13, 2022. It includes a systematic analysis and description of the processing, an analysis of the parties involved, an evaluation of the necessity and proportionality of the processing, and an evaluation and management of the risks, listing the measures adopted for its mitigation.

-

In response to our request for them to provide evidence of the communication made regarding the incident to the affected individuals, they provide an Excel list containing the Email and Name/Surname of the communicated individuals, but the date on which the communication was sent is not detailed. On August 2, 2023, a new request for information is made to the responsible party VIVUS regarding the following actions:

-

The correct accreditation of the communications made.

-

The start date of the data processing activity “Customer Registration And Contract Signing.”

-

Confirmation of whether risk analyses existed prior to May 2022, and their accreditation if applicable. On August 18, 2023, and under entry record REGAGE23e00056162842, a response is received to the previous request, from which the following relevant information for the investigation is extracted:

-

The mass communication sent to the affected clients is accredited, dated April 11, 2023, at 20:09.

-

They state that the data processing activity called “Customer Registration And Contract Signing” began on December 20, 2012, with the registration of the first client on the platform.

-

Regarding the confirmation of whether risk analyses had been conducted prior to the date they had already provided (May 2022), the following is stated:

☐

That after the entry into force of the GDPR, internal and external audits in data protection have been carried out, one of which was at the end of 2019, in which the need to carry out and document risk analyses that complied with Article 32 of the GDPR was detected. As a consequence, “the company prepared a risk analysis in May 2020 in Excel format (Risk Assessment Spain) that included the probability of occurrence of certain risks. Not

14/33

notwithstanding, according to the findings in the subsequent external audit report of the year 2021, said risk analysis did not adequately capture the risks to the rights and freedoms of the affected individuals.” A screenshot of this Excel document is provided.

From the analysis by the present inspector, it is concluded that risk factors are analyzed in a generalized manner and not for a specific processing activity. Furthermore, it is conducted from the perspective of the consequences and impact for the company itself (economic losses and financial impact), thus not constituting a risk analysis for the processing activity affected by the breach that would take into account threats both to the security of the processing and to the rights and freedoms of the data subjects.

☐ A new document titled “RISK ANALYSIS REPORT RELATING TO DATA PROTECTION” dated May 29, 2021, and signed by the Data Protection Officer is provided. From the analysis of this document by the present inspector, it is concluded:

☐ In the introduction, the following text is stated: “This document is the result of the activities constitutive of the Data Protection Impact Assessment (hereinafter DPIA), in accordance with the provisions of Articles 35 and 36 of Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, and the practical guidelines developed by the AEPD.”

☐ It contains the following sections: Preparatory and Organizational Aspects, Identification of Affected Data, and Risk Level Assessment.

☐ In the section regarding the assessment of the risk level, the following identified risk factors are analyzed:

☐ Illegitimate intrusion into systems.

☐ Internal fraud.

☐ Human and technological errors (both in loan management, claims management, commercial communications, and employee data management).

☐ This analysis is not specific to the processing activity affected by the breach and does not take into account risk factors for the rights and freedoms of the individuals affected by the processing activity.

☐ It is stated that at a later date, a specific risk analysis was indeed developed by processing activity following the Risk Management Guide of this Agency. This analysis corresponds to the one provided in response to the previous requirement and is dated May 2022.

☐ They assert that the company is working on the implementation of a software tool (CompaaS) that will allow for a more effective and agile management of its obligations, as well as to periodically record and review its risk analysis in the area of data protection.

CONCLUSIONS

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
15/33

1. The attack vector of the breach was caused by the illegitimate access by the attackers to the web area of multiple clients, using valid credentials that they previously knew (DNI or Email + Password pairs), possibly due to some leak. The modus operandi was as follows:

- Once the attackers accessed the personal area of the affected client, they proceeded to request loans that were automatically accepted, with the amount being deposited into the bank account associated with the client.

- Subsequently, the attackers contacted the clients via WhatsApp pretending to be VIVUS, informing them that a new loan had been mistakenly granted in their name and requesting its return to an account number controlled by the attackers themselves.

2. It has been confirmed that the breach affected 9,497 VIVUS clients whose identities were impersonated, having requested personal loans in the name of many of them that were automatically granted by the platform.

3. The data leaked through the client web area consisted of: first and last names, date of birth, postal address, email, mobile phone, DNI/NIE, IBAN, pseudonymized bank card, as well as data related to loans that were in force with the company.

4. It has been confirmed that VIVUS initially detected the breach on August 11, 2022, following communication received from an affected client. Subsequently, on September 1, 2022, the company was aware of at least 11 affected cases, and on November 14, 2022, at least 83 affected clients. However, the breach was not reported to the present authority until February 17, 2023, when it was already known that at least 427 individuals had been defrauded.

5. It has been established that VIVUS analyzed the level of risk and severity of the breach on different dates (August 11, 2022, September 1, 2022, and November 14, 2022), using an internal methodology based on ENISA that consisted of using a formula to calculate the final risk value based on variables such as the Incident Context, the Ease of Identification, and the Circumstances of the incident, assigning a value to each of these variables according to a scale detailed in the methodology itself. From the final risk value obtained from the previous formula, the claimed party considered that it was NOT necessary to notify the AEPD or the affected individuals.

6. It has been confirmed that the value assigned to some of these variables was lower than what should have been assigned, taking into account the knowledge that was available about the incident at that time. After the present inspector used the tools Asesora Brecha and Comunica Brecha utilizing the information that VIVUS knew in September 2022, the result obtained in both tools indicated the need to notify both the AEPD and the affected individuals.

7. Regarding the communication of the breach to the affected individuals, it has been established that the responsible party ultimately communicated the incident to all affected individuals on April 11, 2023, after receiving the order to communicate from this authority.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
16/33

8. It has been established that there were no specific risk analyses for the rights and freedoms of the individuals concerned regarding the processing activity affected by the breach until May 6, 2022. Prior to this date, there were risk analyses that were not specific to a processing activity and were directed at the possible financial impact on the data controller itself, without analyzing risks to the rights and freedoms of the individuals affected by the processing. It has also been proven that the processing activity affected by the breach was listed in the VIVUS Register of Processing Activities and that it began in December 2012.

9. The existence of a Data Protection Impact Assessment (DPIA) for the processing activity affected by

the breach, conducted on May 13, 2022, has been confirmed, which includes the following information:

- A systematic analysis and description of the processing
- An analysis of the necessity and proportionality of the processing
- An analysis and management of the risks.

10. In relation to the preventive measures implemented prior to the breach, the following list has been noted:

- Security monitoring: review of events, security testing, and vulnerability assessment.
- Password policy with minimum complexity rules for logging into the customer web area.
- Measures against brute force attacks based on waiting times after failed login attempts.
- Firewalls and protection against malware.
- Prevention of DDoS attacks, SQL injection, and other threats through the Imperva Web Application Firewall software.
- Penetration testing of the vivus.es website in June 2023; previously (February 2022), another penetration test had been conducted, but focused on the VIVUS mobile application.
- Internal procedure for managing security incidents.

11. In relation to the reactive measures implemented by the data controller after the security breach was discovered, the following have been noted:

- Implementation of a Two-Factor Authentication (2FA) system on February 21, 2023. They claim that the implementation of this measure was key to resolving the breach as no subsequent cases were detected.
- Resetting all customer passwords on February 11, 2022.
- Inclusion of customers affected by fraud in a special category to avoid possible consequences.
- Improvement of the SIEM monitoring system with the implementation of new real-time event analysis functionalities, specifically:
 - ☐ Alerts are generated when failed authentication attempts from the same IP exceed a defined daily threshold.
 - ☐ Alerts are generated when successful authentication events from the same IP occur on more than four customer accounts.
 - ☐ Blacklists of suspicious IPs for monitoring new authentications received.
- Communication to all customers informing them that the entity does not use WhatsApp as a contact method.
- Update of the internal incident management procedure (as of April 29, 2023), reviewing the template to assess the risk and severity of an incident affecting personal data, introducing adjustments in response times to comply with GDPR notification.

12. Regarding the customer identification process for granting loans, it has been established that all affected customers had already requested a first loan previously and, therefore, had already completed the identification and initial registration process in the system (which requires the user to provide identifying documentation or use the external online banking identification service TINK). However, it has been confirmed that, for the application of second and subsequent loans, VIVUS only required proper authentication in the customer web area using the username (DNI or Email) and their password. Subsequently, as a reactive measure after the breach, VIVUS implemented two-factor authentication (2FA) in the authentication (login) process for customers in the web area, using SMS to send a secure one-time code valid for a single connection to the customer's personal web area, with no new cases of fraud known following the implementation of this measure.

13. From the analysis of the accredited preventive and reactive measures, deficiencies have been noted in the implementation of technical measures to ensure the identity of users requesting second (and subsequent) loans through the web area. The introduction of the second factor of authentication (2FA) as a reactive mechanism, despite not being a method that ensures total protection against attacks, offers a higher level of security, preventing cases of identity theft even when customer passwords have already been compromised. Maximizing the security of the authentication process was deemed appropriate, considering the potential impact of the ability to request loans with the only requirement being correct authentication on the web portal.

14. On the other hand, deficiencies have also been detected in the preventive technical measures

implemented to monitor and, fundamentally, alert in the event of multiple failed login attempts.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

18/33

THIRD: According to the report gathered from the AXESOR tool, the entity 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U. is a large company with a turnover of 66,551,000 euros in the year 2022.

LEGAL GROUNDS

I

Jurisdiction

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Data Protection Agency is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Data Protection Agency shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, to the extent that they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In this case, according to the provisions of Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that VIVUS carries out this activity in its capacity as data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

"Data controller" or "controller": the natural or legal person, public authority, service, or other body that, alone or jointly with others, determines the purposes and means of the processing; as determined by Union or Member State law.

For its part, Article 4.2 of the Regulation defines the "processing" of personal data as "any operation or set of operations performed on personal data or sets of personal data, whether by automated means or not, such as collection, recording, organization, structuring, storage, adaptation or alteration, retrieval, consultation, use, communication by transmission, dissemination or any other form of enabling access, alignment, combination, restriction, erasure or destruction."

III

Obligation Breached under Article 5.1 f) of the GDPR

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

19/33

Article 5.1 of the GDPR establishes the principles relating to processing, indicating, among other issues, that personal data shall be:

"f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures ('integrity and confidentiality')."

The principle of confidentiality, within the framework of the GDPR, implies the obligation to ensure that personal data is kept protected and can only be accessed by those who are authorized to process it, for the purpose intended and/or consented to by the data subjects.

In this regard, the GDPR defines personal data as "any information relating to an identified or identifiable natural person ('data subject'); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier, such as a name, an identification

number, location data, an online identifier, or one or more specific elements of the physical, physiological, genetic, mental, economic, cultural, or social identity of that natural person;” In the case at hand, from the investigative actions carried out by this authority, there is evidence of a presumed violation of the aforementioned principle of confidentiality. This violation is manifested through the following circumstances:

- The fact, confirmed by the accused party, that attackers accessed personal data of customers through their illegitimate access using valid credential combinations (pairs of ID or Email + Password). Regardless of how they accessed such credentials, their use to access the personal information of the affected individuals constitutes a manifestation of the violation of the aforementioned principle.
- The subsequent contact of the attackers with the affected customers posing as the accused party to request the return of money to accounts controlled by the attackers. It should also be noted that the successful outcome of the fraud was not only based on the unlawfully obtained personal information but also relied on the trust that customers placed in VIVUS.
- The various complaints filed by the affected individuals to this authority that emerged in response to the illegal actions and that highlight both the exposure of their personal data without their consent and the subsequent reactive management of the situation by VIVUS.
- The report filed by the accused party and subsequently expanded before the security forces in which they highlighted the number of known affected individuals at that time, in order for them to carry out the appropriate actions.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
20/33



The communication of the breach by the party being claimed, made both to the present authority and to the affected individuals themselves. Although this communication was made in a delayed and progressive manner, it constitutes an acknowledgment of the violation of the confidentiality of the personal data of the affected individuals. It is worth noting that the violation of the principle of confidentiality in this case involves a set of personal data whose nature amplifies the implications of the security breach. This is evident from the circumstance that among the data, in addition to identifying or contact information such as names, addresses, ID numbers (DNI/NIE), and phone numbers, there were also various financial data of the users, such as IBAN and information about existing loans.

The combination of this type of personal data, including knowledge of the financial status of the clients, significantly raises the level of risk and the implications of the breach of confidentiality. This is due to the fact that such a combination not only increases the amount of information available to a malicious actor but also broadens the spectrum of possible abuses. Since these are not isolated data or individual pieces of information, but rather the exposure of an integrated set of personal and financial data, when combined, they can be used to construct a complete and detailed profile of an individual's financial and personal situation, which may allow an attacker to carry out fraud and identity theft operations with a higher success rate.

Specifically, the creation of a profile on the affected individuals allows attackers to design highly personalized deception strategies, such as phishing or scamming, significantly increasing the probability of success. It should be noted that detailed information facilitates the creation of credible messages that can deceive victims into revealing even more information or taking actions that compromise their financial and personal security.

In the same way, unauthorized access and exposure of financial data, such as information about loans, place the affected individuals in a position of significant financial vulnerability. This level of access, in addition to jeopardizing the financial assets of the affected individuals, can also have a lasting negative impact on their credit history and financial reputation. Similarly, information about requested loans, aside from being sensitive from a financial perspective, may contain details about the economic situation and personal needs of the clients that could be used against their will. This

information can motivate not only fraudulent behaviors but also manipulation and blackmail, as malicious actors may exploit knowledge of a person's financial vulnerabilities to pressure or induce them to take actions against their will or interests.

Finally, the considerable number of affected individuals from the breach, which reached 9,497 clients, cannot be overlooked. This circumstance also significantly amplifies the severity of the violation of the principle of confidentiality. It should be taken into account that a high number of affected individuals not only indicates the...

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
21/33

the scale of the incident, but also multiplies the opportunities for misuse of personal information, which exponentially increases the risk of fraud or identity theft, as previously indicated.

IV

Typification and qualification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements typified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to a maximum of 4% of the total annual global turnover of the preceding financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements," establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. Based on what is established in Article 83.5 of Regulation (EU) 2016/679, the following shall be considered very serious and shall be subject to a three-year statute of limitations:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Sanction for the infringement of Article 5.1.f) of the GDPR

According to Article 83.2 of the GDPR, "Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and harm suffered;

b) the intentionality or negligence in the infringement;

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

22/33

c) any measures taken by the controller or processor to mitigate the damage and harm suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or

organizational measures they have applied under Articles 25 and 32;

- e) any previous infringement committed by the controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or processor in relation to the same matter, the compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

Similarly, Article 76 of the LOPDGDD establishes a series of criteria for assessing the possible sanction, following the provisions of paragraph k) of the previous article:

“According to the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any data subject.”

Taking into account these provisions, in the present case it is considered appropriate to assess the sanction to be imposed in the following terms:

- a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of data subjects affected and the level of damage and harm suffered;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

23/33

The concurrence of the aggravating factor in the violation of the principle is manifested in the nature, severity, and duration of the infringement. The nature of the infringement, which involved the exposure of personal and financial data, highlights the significant risk to the rights and freedoms of the affected individuals, especially considering the potential for financial fraud and identity theft. The severity is manifested by the direct impact on the financial and personal integrity of the clients, as well as the potential long-term damage to their trust and perception of security. Furthermore, the duration of the infringement, which ceased after the effective implementation of corrective measures, unnecessarily extended the period of vulnerability of the clients' personal data, broadening the timeframe during which the data were exposed to security risks.

Likewise, the concurrence of the aggravating factor is also manifested in the number of affected parties, as it impacted more than 9,000 clients, which underscores both the scale of the incident and the considerable volume of individuals whose rights and freedoms were compromised. This wide-reaching impact amplifies the severity of the infringement, as each affected client represents a potential case of fraud, identity theft, or financial loss, exponentially multiplying the negative repercussions of the incident.

Aggravating factor provided for in section b) of Article 83.2 of the GDPR:

b) the intentionality or negligence in the infringement;

The Supreme Court has understood that there is recklessness whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. In this sense, it establishes that in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, a professionalism that is present in this case, given that the activity of the appellant involves constant and abundant management of personal data, which implies greater rigor and care in order to comply with legal provisions.

In this case, although direct intentionality is not suggested, negligence emerges both in the delay in notifying the affected parties of the breach (which occurred after a request from this entity) and in the late reaction after becoming aware of the breach of confidentiality of their clients' personal data. These elements reflect an omission in the duty of care that VIVUS had towards the protection of its clients' data, which reinforces and amplifies the severity of the infringement and consequently justifies the concurrence of this aggravating factor.

Aggravating factor provided for in section b) of Article 76 of the GDPR:

b) The link of the infringer's activity with the processing of personal data.

Considering that the core of VIVUS's business activity is based on granting loans and, therefore, on the intensive processing of personal and financial data, this link deepens the severity of the infringement. The company operates in a sector where trust and information security are fundamental, and for this reason, it has the responsibility to ensure with greater rigor the principles of data protection regarding the information it manages in virtue of this activity, among which are sensitive data, such as banking data.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

24/33

financial year. The nature of VIVUS's activity, consequently, amplifies the consequences of the alleged infringement, a circumstance that justifies the presence of this aggravating factor.

Based on the aforementioned circumstances, in accordance with the provisions of Article 83.5 of the GDPR, and without prejudice to the outcome of the instruction of this procedure, it is deemed appropriate to set a possible sanction of a fine in the amount of €200,000 (TWO HUNDRED THOUSAND EUROS).

VI

Obligation Breached under Article 32 GDPR

Article 32 "Security of Processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying likelihood and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data promptly in the event of a physical or technical incident;

d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data on instructions from the controller, unless required to do so by Union or Member State law.”

It is necessary to point out that the aforementioned provision does not establish a list of specific security measures according to the data being processed, but rather establishes the obligation for the controller and the processor to apply technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

25/33

nature, scope, context, and purposes of the processing, the probability and severity risks to the rights and freedoms of the data subjects.

Likewise, the security measures must be adequate and proportionate to the detected risk, determining those technical and organizational measures that are appropriate, taking into account pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, verification process (which is not an audit), evaluation, and assessment of the effectiveness of the measures.

In any case, when assessing the adequacy of the level of security, particular attention must be paid to the risks presented by the data processing, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data that could cause physical, material, or immaterial harm.

In this regard, Recital 83 of the GDPR states that “(83) In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or the processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data that needs to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the destruction, loss, or accidental or unlawful alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which are particularly likely to cause physical, material, or immaterial harm.”

In the present case, in accordance with the evidence available in this initiation agreement of the sanctioning procedure, and without prejudice to the outcome of the instruction, it is considered that the known facts could constitute an infringement, attributable to the accused party, for violation of Article 32 of the GDPR.

The accusation under Article 32 of the GDPR in the context of VIVUS is based on the alleged deficiencies identified in the application of appropriate technical and organizational security measures to ensure an appropriate level of security concerning the risk posed by the processing of personal data. From the investigative actions carried out by this authority, various circumstances have emerged that indicate a non-compliance with the specific requirements of the article.

Thus, although VIVUS conducted risk analyses on different dates using an internal methodology based on ENISA, it is evident from the prior actions that there was an incorrect assignment of values to key variables, which implies a significant underestimation of the risk and severity of the breach. This indicates a possible inadequacy in the risk assessment by not taking into account the state of the art, the costs of implementation, and the risks to the rights of individuals.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

In the same way, the delay in communicating the incident to the affected parties until April 11, 2023, after receiving the order from the competent authority, highlights a limitation in VIVUS's ability to ensure the ongoing confidentiality, integrity, availability, and resilience of data processing systems and services. This delay in notification could pose greater risks to the affected individuals, thereby failing to comply with the obligation under Article 32 to restore the availability and access to personal data promptly in the event of an incident.

Furthermore, the lack of specific risk analysis for the rights and freedoms of the data subjects involved in the processing activity, and the focus on financial impacts for VIVUS instead of the risks to the affected individuals, underscores an inadequate approach to data protection from an individual-centered perspective.

The implementation of reactive measures by VIVUS, while necessary and useful to address the consequences of the security breach, simultaneously reveals shortcomings in anticipating and mitigating risks to the security of personal data. This highlights the importance of continuous risk assessment, proactive security planning, and agile incident response, in accordance with the requirements of Article 32 of the GDPR, all of which have not been taken into account by VIVUS, as deduced from the actions taken.

In this regard, VIVUS's initial decision to allow new successive loan applications based solely on a user and password authentication method reveals an underestimation of the risks associated with identity theft and financial fraud. Based on the premise that the affected customers had already completed an identification process for their first loan, VIVUS's system did not require rigorous identity verification for subsequent transactions. This practice opens the door for malicious actors, if they obtain access credentials from customers, to fraudulently apply for loans.

The implementation of Two-Factor Authentication (2FA) by VIVUS undoubtedly constitutes a significant advancement in the protection of data security and the integrity of its financial transactions. However, this advancement comes at a reactive moment, after critical vulnerabilities have manifested and a security breach with wide-ranging effects has occurred. The adoption of 2FA, while crucial, represents a missed opportunity to have proactively anticipated and mitigated risks before they materialized into actual harm for customers, which is, in essence, the purpose pursued by the aforementioned Article 32.

The aforementioned deficiencies detected in the preventive measures prior to the breach, especially regarding user authentication for the application of successive loans, underscore the need for an adequate risk assessment as stipulated by Article 32 of the GDPR. As indicated in the conclusions of the investigative actions, despite the significant improvement represented by 2FA, the situation highlights shortcomings in the technical preventive measures prior to the breach, particularly concerning monitoring.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

of failed login attempts and the generation of alerts. The lack of an effective system to detect anomalous authentication patterns facilitates potential attackers' exploitation of compromised credentials without being detected in a timely manner.

The nature of VIVUS's activity cannot be overlooked in this case, as it operates in the financial sector, which entails that the processing of personal data involves sensitive information, including financial and personal identification details. The circumstances related to this activity impose a greater requirement regarding technical and security measures in order to protect users' data protection rights. Finally, it is worth noting that the lack of adequate security measures by VIVUS is an issue that goes beyond the specific security breach that occurred. While the implementation of reactive measures such as Two-Factor Authentication (2FA) and the improvement of the SIEM monitoring system were important steps in response to the breach, VIVUS's non-compliance lies in a broader and pre-existing

omission: the failure to adopt a comprehensive and proactive data security framework.

This lack of adequate security measures, regardless of the breach, indicates a disconnect between the assessment of potential risks and the implementation of the necessary technical and organizational measures to prevent such incidents. The situation highlights a disconnect in VIVUS's information security culture, where measures tend to be reactive rather than aligned with a proactive and risk-based security strategy. This reactive stance limits the effectiveness of security measures and increases vulnerability to future breaches, as not all necessary security measures are directly related to the prevention of specific incidents, but rather to the creation of a secure environment in a comprehensive manner.

In summary, the measures adopted by VIVUS, the nature of its activity, and its reactive management regardless of the security breach underscore an alleged non-compliance with Article 32 of the GDPR, which requires the implementation of appropriate technical and organizational measures to ensure a level of security appropriate to the risk of processing personal data. While VIVUS took reactive measures, these actions came as a response to a vulnerability that had already been exploited, rather than as part of a proactive risk management strategy.

VII

Classification and Qualification of the Violation of Article 32 of the GDPR

If confirmed, the aforementioned violation of Article 32 of the GDPR could constitute the commission of the violations classified in Article 83.4 of the GDPR, which under the heading "General Conditions for the Imposition of Administrative Fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total annual global turnover of the previous financial year, opting for the higher amount:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

28/33

a) the obligations of the controller and the processor in accordance with Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 73 "Infringements considered serious" of the LOPDGDD indicates: "In accordance with what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a two-year statute of limitations: those that involve a substantial violation of the articles mentioned therein and, in particular, the following:

(...) f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security adequate to the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.

VIII

Sanction for the infringement of Article 32 of the GDPR

In the terms indicated by the aforementioned Article 83.4 of the GDPR, the infringement of Article 32 shall be sanctioned "with administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to a maximum of 2% of the total annual global turnover of the previous financial year, opting for the higher amount."

Furthermore, according to the previously established criteria, it is considered that in the present case it is appropriate to scale the sanction to be imposed in the following terms:

Aggravating factor provided for in paragraph a) of Article 83.2 of the GDPR:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected individuals and the level of damage and harm they have suffered;

In the present case, the presence of the aforementioned aggravating factor is evident considering the nature, gravity, and duration of the alleged infringement committed.

In terms of the nature of the infringement, it manifests itself in the inadequate processing of personal and financial data, a critical aspect considering the sensitivity of the information involved. On the other hand, the gravity arises from the potential significant harm to the rights and freedoms of the affected individuals posed by the failure to adopt adequate security measures, including risks of fraud and financial loss. Additionally, the duration of the infringement, extending from the moment of the breach until the delayed implementation of corrective measures, justifies the presence of the aforementioned aggravating factor.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

29/33

Aggravating factor provided for in paragraph b) of Article 83.2 of the GDPR:

b) the intentionality or negligence in the infringement;

In the terms previously indicated regarding the doctrine of the Supreme Court concerning negligence, in this case, negligence is manifested in the lack of foresight and the delayed adoption of measures such as 2FA, which are fundamental for the protection of personal data. This negligence indicates an omission in the application of a proactive and risk-based data security approach, essential to prevent unauthorized access and other forms of data compromise. Negligence, therefore, is manifested in this case by failing to anticipate and mitigate risks, especially in such a sensitive sector as finance, which justifies the presence of the aforementioned aggravating factor.

Aggravating factor provided for in paragraph b) of Article 76 of the GDPR:

b) The link of the infringer's activity with the processing of personal data.

The infringement of Article 32 by VIVUS is particularly aggravated by the close link of its business activity with the intense and ongoing processing of personal data, given that the granting of loans involves the management of personal and financial information in a regular and massive manner. In this sense, the lack of adequate security measures jeopardizes the essence of the operations on which such entities are based and undermines trust in the digital financial sector. Similarly, the nature of this activity required greater rigor in the adoption of security measures, a requirement that was not fulfilled in the case at hand.

Taking into account the general conditions for the imposition of administrative fines established by the aforementioned Article 83.2 of the GDPR, considering the circumstances of the present case and without prejudice to what results from the instruction of this procedure, a possible sanction of a fine in the amount of €400,000 (FOUR HUNDRED THOUSAND EUROS) is proposed.

IX

Adoption of measures

If the infringement is confirmed, it could be agreed to impose on the controller the adoption of appropriate measures to adjust its actions to the regulations mentioned in this act, in accordance with what is established in the aforementioned Article 58.2 d) of the GDPR, according to which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specified manner and within a specified timeframe...”. The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided for in Article 83.2 of the GDPR.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

30/33

It is warned that failure to comply with the possible order for the adoption of measures imposed by this body in the sanctioning resolution may be considered an administrative infringement in accordance

with the provisions of the GDPR, classified as an infringement in its articles 83.5 and 83.6, which may lead to the initiation of further administrative sanctioning proceedings.

Therefore, in light of the above, by the Director of the Spanish Agency for Data Protection, IT IS AGREED:

FIRST: TO INITIATE SANCTIONING PROCEDURE against 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U., with NIF A86521309, for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified in Article 83.5 of the GDPR and Article 83.4 of the GDPR.

SECOND: TO APPOINT R.R.R. as instructor and S.S.S. as secretary, indicating that they may be recused, if applicable, in accordance with the provisions of articles 23 and 24 of Law 40/2015, of October 1, on the Legal Regime of the Public Sector (LRJSP).

THIRD: TO INCORPORATE into the sanctioning file, for evidentiary purposes, the various complaints filed and their documentation, as well as the documents obtained and generated by the General Subdirectorate of Data Inspection in the actions prior to the initiation of this sanctioning procedure.

FOURTH: THAT for the purposes provided in article 64.2 b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the sanction that may correspond would be, without prejudice to what results from the instruction:

- For the alleged infringement of article 5.1.f) of the GDPR, classified in article 83.5 of that regulation, an administrative fine of 200,000.00 euros.
- For the alleged infringement of article 32 of the GDPR, classified in article 83.4 of that regulation, an administrative fine of 400,000.00 euros.

FIFTH: TO NOTIFY this agreement to 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U., with NIF A86521309, granting a hearing period of ten working days for it to submit allegations and present any evidence it deems appropriate. In its written allegations, it must provide its NIF and the file number that appears in the heading of this document.

If no allegations are made against this initiation agreement within the stipulated period, it may be considered a proposal for resolution, as established in article 64.2.f) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP).

In accordance with the provisions of article 85 of the LPACAP, it may acknowledge its responsibility within the period granted for the formulation of allegations to this initiation agreement; this will entail a reduction of 20% of the sanction that may be imposed in this procedure. With the application of this reduction, the sanction would be set at 480,000.00 euros, resolving the procedure with the imposition of this sanction.

Similarly, it may, at any time prior to the resolution of this procedure, voluntarily pay the proposed sanction, which will imply a reduction of 20% of its amount. With the application of this reduction, the sanction would be set at 480,000.00 euros and its payment will imply the termination of the procedure, without prejudice to the imposition of the corresponding measures.

The reduction for the voluntary payment of the sanction is cumulative with the one corresponding to the acknowledgment of responsibility, provided that this acknowledgment of responsibility is made within the period granted to formulate allegations to the opening of the procedure. The voluntary payment of the amount referred to in the previous paragraph may be made at any time prior to the resolution. In this case, if both reductions were to apply, the amount of the sanction would be set at 360,000.00 euros.

In any case, the effectiveness of either of the two mentioned reductions will be conditioned upon the withdrawal or renunciation of any action or administrative appeal against the sanction.

In the event that it opts to proceed with the voluntary payment of any of the amounts indicated above (480,000.00 euros or 360,000.00 euros), it must do so by depositing it into account no. IBAN:

ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX) opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A., indicating in the concept the reference number of the procedure that appears in the heading of this document and the reason for the reduction of the amount to which it is entitled.

Additionally, it must send the proof of payment to the General Subdirectorate of Inspection to continue with the procedure in accordance with the amount deposited.

The procedure will have a maximum duration of twelve months from the date of the initiation agreement. If this period elapses without a resolution being issued and notified, it will expire, and consequently, the file will be archived; in accordance with the provisions of article 64 of the LOPDGDD.

Finally, it is noted that in accordance with the provisions of article 112.1 of the LPACAP, there is no administrative appeal against this act.

935-18032024

Mar España Martí

Director of the Spanish Agency for Data Protection

>>

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

32/33

SECOND: On April 25, 2024, the respondent has proceeded to pay the fine in the amount of 360,000 euros, making use of the two reductions provided for in the previously transcribed Initiation Agreement, which implies the acknowledgment of responsibility.

THIRD: The payment made, within the period granted to submit allegations regarding the opening of the procedure, entails the waiver of any action or administrative appeal against the fine and the acknowledgment of responsibility concerning the facts referred to in the Initiation Agreement.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, as long as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Termination of the procedure

Article 85 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), under the heading "Termination in sanctioning procedures" provides as follows:

"1. Once a sanctioning procedure has been initiated, if the offender acknowledges their responsibility, the procedure may be resolved with the imposition of the appropriate sanction.

2. When the sanction is solely of a pecuniary nature or when it is possible to impose a pecuniary sanction and another of a non-pecuniary nature but the imposition of the latter has been justified as inappropriate, voluntary payment by the presumed responsible party, at any time prior to the resolution, will imply the termination of the procedure, except regarding the restoration of the altered situation or the determination of compensation for the damages caused by the commission of the infringement.

3. In both cases, when the sanction is solely of a pecuniary nature, the competent authority to resolve the procedure shall apply reductions of at least 20% on the amount of the proposed sanction, which shall be cumulative. The aforementioned reductions must be specified in the notification of initiation of the procedure, and their effectiveness shall be conditioned upon the withdrawal or waiver of any action or administrative appeal against the sanction. The percentage of reduction provided for in this section may be increased by regulation."

In accordance with the above,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO DECLARE the termination of procedure EXP202304633, in accordance with the provisions of Article 85 of the LPACAP.

SECOND: TO NOTIFY this resolution to 4FINANCE SPAIN FINANCIAL SERVICES, S.A.U.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative process as provided by Article 114.1.c) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the interested parties may file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating Contentious-Administrative Jurisdiction, within a period of two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

936-040822

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es